# 4.2.6 Applying Compensating Controls

Securing AI systems requires adaptive, context-aware controls that go beyond traditional static defenses. This lesson covers the key compensating controls tailored to AI's unique attack surfaces from prompt filtering to encryption-in-use.

SECAI+ PREP

LESSON 4.2.6

# Prompt Firewalls

The first line of defense against malicious input targeting large language models.

### Intercept & Analyze

Inspect user input **before it reaches the model**, stopping threats at the entry point.

### Multi-Layer Detection

Combine pattern-matching, ML classifiers, and user context awareness for robust coverage.

### Block Suspicious Prompts

Flag or block inputs that could override model constraints or manipulate behavior.

### Anti-Injection Defense

Primary defense against **prompt injection attacks** in LLMs and AI-powered applications.

# Model Guardrails

## What Are Guardrails?

Logic-based constraints, safety policies, or external validators that monitor and **correct model outputs in real time** keeping behavior within acceptable operational boundaries.

Unlike input-side defenses, guardrails act at the **output layer**, catching unsafe or non-compliant responses before they reach the user.

## Real-World Example

A **medical chatbot** uses guardrails to automatically reject any output that contradicts verified clinical guidelines preventing dangerous misinformation from reaching patients.

## Key Functions

- Enforce safety policies post-generation
- Validate outputs against external knowledge bases
- Trigger fallback responses when thresholds are breached
- Log violations for audit and continuous improvement

# Least Privilege & RBAC

AI pipelines span data engineering, training, inference, and deployment — each stage carries distinct permission requirements that must be tightly controlled.

## Least Privilege Principle

Apply minimal access rights at **every touchpoint** across the AI pipeline. Limits the blast radius from insider threats or compromised credentials — no single breach can cascade unchecked.

## Role-Based Access Control (RBAC)

Ensure users and services only access what they need for their specific role. Granular permission tiers prevent unauthorized access to training data, model weights, or inference outputs.

## Multi-Tenant & API Environments

Critical in **multi-tenant and API-exposed environments** where shared infrastructure creates risk of cross-tenant training data or output extraction by malicious actors.

# Data Integrity & Prompt Templates

## Data Integrity Monitoring

Cryptographic verification of training data provenance ensures that datasets have not been tampered with or poisoned before model training begins.

### Hash-Based Validation

Detect unauthorized changes to training datasets at the file level.

### Blockchain-Backed Logging

Immutable audit trails for data provenance and lineage tracking.

### Digital Signatures

Verify authenticity of data sources and model artifacts.

## Prompt Templates

Pre-approved structured input formats that enforce consistency and encode business logic directly into the interaction layer.

> Paired with NLP validation tools, prompt templates sanitize input and significantly limit injection risk and can be updated as attack methods evolve.

- Restrict free-form input to validated structures
- Encode business rules and safety constraints
- Enable security teams to review and iterate formats
- Reduce attack surface for adversarial prompt crafting

# Rate Limiting & Encryption

Layered data protection strategies that defend AI systems from extraction attacks and unauthorized access especially critical in high-risk domains like finance, defense, and healthcare.

### Rate Limiting

Restrict queries per user/session to prevent **membership inference**, brute-force data extraction, and API abuse.

### Encryption at Rest

Protect training datasets and model artifacts with **industry-standard encryption** when stored.

### Encryption in Transit

Secure all data moving between components during **training and inference** pipelines.

### Encryption in Use

**Homomorphic encryption** and secure enclaves protect data even while actively in memory.

# Adaptive Security Mindset

## Why Static Defenses Fail

AI systems are **dynamic** — they evolve through continuous learning, retraining, and user feedback loops. A control that works today may be obsolete tomorrow as the model and its threat landscape shift.

Security professionals must treat AI as a **living system**, not a fixed artifact deployed once and forgotten.

## Adaptive Security Practices

01

### Ongoing Risk Assessments

Continuously evaluate the threat landscape as the model evolves and new attack vectors emerge.

02

### Attack Simulations

Regularly red-team AI systems with adversarial prompts, poisoning attempts, and extraction probes.

03

### Iterative Hardening

Update controls, guardrails, and prompt templates in response to simulation findings and real incidents.

04

### Context-Aware Controls

Ensure defenses adapt to deployment context — production, staging, multi-tenant, or high-risk domain.

# Key Takeaways

### Prompt Firewalls

Filter malicious input **before it reaches the model** — the critical first line of defense against injection attacks.

### Model Guardrails

Enforce safe, compliant behavior at the **output layer** in real time, catching violations post-generation.

### Least Privilege & RBAC

Limit blast radius across every stage of the AI pipeline by restricting access to only what is needed.

### Data Integrity & Prompt Templates

Cryptographic verification protects against poisoning; structured templates reduce injection risk.

### Rate Limiting & Encryption

Mitigate extraction attacks and protect data **at rest, in transit, and in use** — foundational for all AI deployments.

### Adaptive Security

AI security demands **continuously updated, context-aware controls** — not one-time static configurations.